

PRIVACY REPORT

개인정보 이슈 심층분석

개인정보보호 중심 설계(PbD)

PRIVACY REPORT

2025년
개인정보 이슈
심층분석

CONTENTS

1

국내외 PbD 인증 시범사업 소개 및 향후 전망 3

서혁준 / LG CNS RED팀 | 보안사업담당 RED팀 총괄 MEISTER

2

PbD 원칙과 관련한 국제 표준 및 인증 제도 동향 9

지성우 / 성균관대학교 법학전문대학원 | 교수

3

AI 환경에서의 PbD 적용방안 16

조수영 / 숙명여자대학교 법학과 | 교수

국내외 PbD 인증 시범사업 소개 및 향후 전망

서혁준

LG CNS RED팀 | 보안사업담당 RED팀 총괄 MEISTER

1. 제품 PbD(Privacy by Design) 개요 및 필요성

■ 국민이 일상에서 자주 접하는 로봇청소기의 카메라가 가정 내부를 엿보는 데 악용되거나, 아동의 스마트워치에서 위치 정보가 부모 외의 승인되지 않은 제3자에게 전송되는 상황이 발생한다면 국민이 매우 불안해할 것이다.

이처럼 개인정보 보호 기능 구현이 미흡하거나 해킹에 취약하여 사생활 침해 가능성이 조금이라도 있다면 제조사는 제품 소프트웨어를 수정하여 펌웨어를 재생성하여 배포해야 하는데, 제작 중인 제품과 이미 유통되어 사용 중인 제품 버전에 차이가 있어 업데이트 제작에 어려움이 생기고, 시중 제품의 하드웨어 구성이 달라 소프트웨어 업데이트가 불가능한 경우도 적지 않다.

따라서, 제품 개발의 경우 제품 개발 초기 단계부터 프라이버시를 사전에 고려하고 설계에 내재화하는 '개인정보보호 중심 설계(Privacy by Design, PbD)'¹⁾ 원칙을 준수하는 일이 더욱 중요하다.

2. 이용자 보호를 위해 강화되는 해외 제품 보안

■ PbD의 법제화 방식은 국가마다 차이가 있다.

미국은 2025년부터 연방통신위원회(Federal Communications Commission, FCC)를 통해 미국 내 판매되는 스마트 기기를 대상으로 '사이버 트러스트 마크(Cyber Trust Mark)'²⁾ 제도를 시행하고 있으며, 이는 기업이 미국 정부가 정한 개인정보 보호 및 보안 기준을 충족하는지 종합적으로 평가한다. 2027년부터는 인증된 제품만 연방 정부가 구매할 수 있도록 행정명령이 추진 중이다.

유럽연합(EU)은 '사이버 복원력법(Cyber Resilience Act, CRA)'³⁾을 통해 유럽 내 판매 및 유통되는

1) Privacy by Design : 제품 또는 서비스의 기획, 제조, 폐기 등 전 과정에서 개인정보보호 요소를 충분히 고려함으로써 개인정보 침해 예방하는 설계 개념

2) FCC, Federal Communications Commission, Certification Mark - U.S. Cybersecurity Labeling Program for Smart Devices, 2023.09.08.

모든 디지털 제품의 개인정보 관리 전반을 국가가 의무적으로 평가하도록 규정했으며, 이를 준수하지 않을 경우 전 세계 매출의 최대 2.5% 또는 1,500만 유로(한화 약 210억 원)의 과징금이 부과될 수 있다.

유럽의 무선 장비 지침(Radio Equipment Directive, RED)⁴⁾은 네트워크 통신 제품 판매의 조건으로 강화된 보안을 요구하고 있으며, 개인정보를 처리하는 제품에 대해서는 데이터 수집, 저장, 사용, 공유, 삭제 등 프라이버시 보호 요건도 규정하고 있다. CE 마크(Conformité Européenne Marking)⁵⁾를 유지하기 위해서 제조사는 강화된 보안 기준을 준수해야 한다.

3. PbD 인증 및 국내 인증 제도

2023년부터 개인정보보호위원회와 한국인터넷진흥원은 개인정보보호 중심 설계(PbD) 인증을 시범 운영하고 있으며, 개인정보 보호 항목을 인증 항목에 다수 포함하였다. '24년까지는 한국인터넷진흥원이 인증(4개 유형, 69개 항목)을 진행하였으며, '25년부터는 개인정보보호위원회가 인증(4개 유형, 71개 항목)을 운영하고 있다. PbD 인증 항목은 ISMS-P, GSMA 보안 가이드라인, IoT 보안인증 등의 국내·외 인증과 가이드라인을 분석하여 국내 여건에 맞는 4개 유형, 71개 항목으로 정리하였다.

표1 개인정보보호 중심 설계(PbD) 인증기준 (71개)

구분	개수	시험 항목 예시
I. 기본적인 요구사항	14개	개인정보 처리 흐름, 불필요한 개인정보 전달 방지, 개인정보 위험 식별 및 개인정보 보호 통제의 이행 등
II. 개인정보 처리의 적법성	28개	개인정보 동의, 개인정보의 이용 및 제공의 제한, 개인정보 처리의 투명성 보장, 권리 보장 등
III. 정보보안 및 프라이버시 강화	22개	사용자 인증 및 권한 관리, 반복된 인증 시도 제한, 안전한 암호화, 안전한 업데이트 수행, 프라이버시 강화 기술의 적용 등
IV. 조직적 보호조치	7개	개인정보의 안전성 확보, 개인정보보호 책임자 임명, 개인정보 사고 대응 및 소비자와 의사소통 등

PbD 시범 인증 이전인 2021년부터 과학기술정보통신부와 한국인터넷진흥원에서 IoT보안인증⁶⁾을 법제화하여 운영하고 있다. IoT보안인증은 가전 · 교통 · 금융 · 스마트도시 · 의료 · 제조 및 생산 · 주택 · 통신 등 8대 산업 분야 네트워크 연결 기기의 보안성을 평가해 인증서를 발급하고 마크 부착을 허용한다.

IoT보안인증과 PbD 인증은 제품 보안과 개인정보보호 영역에 각기 특화되어 있다. 두 인증을

3) European Cyber Resilience Act, Cyber Resilience Act (CRA), 2024.10.10.

4) EC, Radio Equipment Directive (RED), 2014.06.13.

5) EU 시장에서 판매되는 제품이 유럽의 안전·보건·환경·소비자 보호 규정을 충족했음을 나타내는 적합성 표시.

6) 정보보호산업진흥포털, IoT 보안인증제도, 2021.11.28.

비교하면 아래 표와 같다.

표2 IoT 보안인증과 개인정보 PbD인증 비교

항목	IoT보안인증	PbD인증
정책기관	과학기술정보통신부	개인정보보호위원회
인증시험 기관	한국인터넷진흥원 (산업별 제품 시험 특성을 고려하여 전문 시험 대행 기관을 복수 지정)	한국인터넷진흥원
인증 등급	3개 등급(Lite, Basic, Standard)	단일
국제적 효력	싱가포르 상호 인정 약정(MRA) ⁷⁾ , 독일과 협력을 위한 의향서 체결 ⁸⁾	해당 없음

인증 간 항목을 비교하면, PbD 인증은 개인정보 관련 기본사항, 개인정보 처리의 적법성, 정보 보안 및 프라이버시 강화, 조직적 보호조치를 평가한다. 이 중 'Ⅲ. 정보보안 및 프라이버시 강화' 항목 일부는 IoT보안인증과 중복되는데 제품 보안 기술이 개인정보 보호에도 함께 활용되는 경우가 있기 때문이다. 시험 신청을 하는 제조사 입장에서 만약 두 가지 인증을 동시에 신청하더라도 중복 항목을 재시험하지 않을 수 있으므로 중복 항목이 기업에 부담으로 작용하지는 않을 것이다.

4. 국내 PbD 인증 시범사업 및 대표 사례 소개

개인정보보호위원회는 '23년부터 PbD 인증을 시범 운영하고 있으며, '25년 홈 카메라, 차량용 영상 기록장치, 가정용 로봇, 로봇청소기 4개 제품을 시범 인증 대상 제품으로 선정하여 검증을 추진하고 있다. 현재까지 인증 시험을 통과하여 안전성이 검증된 제품은 4개 제품(가정용 방범 카메라, 개인영상정보 비식별화 시스템, 스마트 키오스크, 로봇청소기)이 있다.

사례 중에서 로봇청소기 제품은 IoT보안인증과 PbD 인증⁹⁾을 동시에 취득했는데, IoT보안인증의 경우 국내 최초로 Standard 등급을 획득했다. 로봇청소기 제품의 개인정보보호 설계 수준은 다음과 같다.

우선, 암호화를 처리하는 하드웨어 보안 칩셋이 사용되었다. 이는 회로기판 설계와 하드웨어 부품 선정 단계에서 진행해야 하므로 설계 초기에 고려되어야 한다. 보안 하드웨어는 일반 하드웨어보다 단가가 비싸므로 제품의 개인정보보호 목표 수준을 정해야 하며 부품 선정 단계에서 결정이 필요하다.

7) KISA, KISA 사물인터넷 보안 분야 국내 최초 상호인정약정(MRA) 체결, 2024.10.16.

8) KISA, KISA-독일(BSI), 사물인터넷(IoT) 보안인증 협력을 위해 의향서 체결, 2024.09.11.

9) Samsung Newsroom, 삼성전자 비스포크 AI 스티, '개인정보보호 중심 설계' 인증 획득, 2024.12.19.

다음으로, 프라이버시를 강화하기 위하여 개인정보의 수집을 최소화하고 제품 스토리지에 저장되는 개인정보를 암호화하였으며 서버 전송 구간에 암호화를 적용했다.

개인정보보호 설계가 되지 않는 PbD 미인증 로봇청소기일 경우 개인정보가 제대로 보호되지 않을 수 있다. 장치와 연동된 앱을 제3자가 불법적으로 접근 및 조작하여 집 내부 촬영 사진이 외부에 노출될 수 있다.

5. 글로벌 기업들의 PbD 인증 사례

■ 글로벌 제조사는 수출 대상국의 법률을 준수해야 하며, 유럽 수출 제품은 GDPR의 PbD 원칙¹⁰⁾에 따라 개인정보 영향평가(Privacy Impact Assessment, PIA)를 자율적으로 수행하거나 외부 인증을 받아 제품 품질을 평가한다. PIA 가이드는 프랑스 개인정보 감독기관(National Commission on Informatics and Liberty, CNIL)이 공개한 문서¹¹⁾를 참고할 수 있다.

자동차 업계는 유엔 유럽경제위원회(United Nations Economic Commission for Europe, UNECE) WP.29의 UN Regulation No.155에 따라 사이버 보안 관리체계(Cyber Security Management System, CSMS)¹²⁾ 인증이 의무화되었다. 유럽·일본·한국이 CSMS를 준수하고 있으며 한국은 자동차관리법에 이를 규정하고 있다. 전장 부품 제조사는 설계 단계에서 위협 분석 및 위협 평가(Threat Analysis and Risk Assessment, TARA)를 수행하고, 보안·안전·개인정보보호 대책을 수립한다. 개발 완료 후에는 설계 단계에서 수립한 위협 시나리오에 대하여 시험 절차를 정의하고 동적 침투테스트(Penetration Test)를 통해 조치 여부를 확인한다.

SaaS(Software as a Service) 사업자와 클라우드 기반 소프트웨어 개발사는 클라우드 환경의 인프라와 서비스에 대해 자율적으로 개인정보 영향평가를 실시하여 발견된 취약성을 조치한다. 고객의 테넌트를 분리 설계할 것인지, 이기종 클라우드에서 동작하는 서비스 간 API의 인증을 어떻게 하면 안전하게 설계할 수 있는지 등을 PbD 관점에서 점검한다.

세계이동통신사업자협회(Global System for Mobile Communications Association, GSMA) 보안 가이드라인¹³⁾을 준수해야 하는 글로벌 통신사는 제품, 서비스, 네트워크 영역에 대한 보안 및 개인정보 위험을 평가한다. 예로, 통신 암호화와 인증에 사용되는 마스터 키를 암호화하려면 설계 단계부터 고려되어야 한다.

10) GDPR-Info.eu, GDPR Privacy by Design, 2018.05.18.

11) CNIL, Privacy Impact Assessment, 2018.02.

12) UNECE, UN Regulation No. 155 - Cyber security and cyber security management system, 2021.03.04.

13) GSMA, GSMA IoT Security Guidelines, 2024.04.26.

5. PbD 구현의 새로운 적용 분야 및 향후 전망

■ 최근 개발되는 서비스나 제품에 대화형 언어모델(LLM)과 딥러닝 AI 기술을 도입하는 사례가 급증하고 있다.

LLM은 웹 챗봇과 서비스 로봇에 널리 활용되고 있으며, 학습에 사용된 고객정보의 유출, 프롬프트 인젝션으로 인한 영향을 최소화하기 위해 PbD(Privacy by Design) 기반의 보완 설계가 요구된다.

딥러닝은 사전 학습된 모델을 업무에 맞게 재학습(미세조정)하여 사용하는 방식으로 확산되고 있다. 이 과정에서 모델 무결성이나 학습 데이터의 신뢰성이 훼손되면 서비스의 공정성과 안전성이 저하될 수 있으므로, 운영 단계의 가드레일뿐만 아니라 설계에 해당하는 전처리 및 미세조정 단계에서 합성데이터 활용, 비식별화 등 PbD 적용이 중요하다.

또한, AI는 자율적 판단과 행동이 가능한 Agentic AI로 진화하고 있다. AI가 편향된 판단을 하거나 불충분한 설명으로 이용자를 오도하지 않도록, AI의 결정 과정과 판단 근거에 대한 투명성을 확보하는 것이 필수적이다.

PbD 인증이 향후 AI를 포함한 다양한 영역에서 개인정보보호 설계를 평가하는 제도로 확대 운영된다면, 제품의 개인정보보호 수준을 높여 국민이 안심하고 인증된 제품을 구매·이용할 수 있는 환경 조성에 기여할 것으로 기대된다.

참고 문헌 |

1. FCC, Federal Communications Commission, Certification Mark - U.S. Cybersecurity Labeling Program for Smart Devices, 2023.09.08.
2. European Cyber Resilience Act, Cyber Resilience Act (CRA), 2024.10.10.
3. EC, Radio Equipment Directive (RED), 2014.06.13.
4. 정보보호산업진흥포털, IoT 보안인증제도, 2021.11.28.
5. KISA, KISA, 사물인터넷 보안 분야 국내 최초 상호인정약정(MRA) 체결, 2024.10.16.
6. KISA, KISA-독일(BSI), 사물인터넷(IoT) 보안인증 협력을 위해 의향서 체결, 2024.09.11.
7. Samsung Newsroom, 삼성전자 비스포크 AI 스템, '개인정보보호 중심 설계' 인증 획득, 2024.12.19.
8. GDPR-Info.eu, GDPR Privacy by Design, 2018.05.18.
9. CNIL, Privacy Impact Assessment, 2018.02.
10. UNECE, UN Regulation No. 155 - Cyber security and cyber security management system, 2021.03.04.
11. GSMA, GSMA IoT Security Guidelines, 2024.04.26.

PbD 원칙과 관련한 국제 표준 및 인증 제도 동향

지성우

성균관대학교 법학전문대학원 | 교수

1. 서론: 개인정보 보호의 중요성과 PbD 원칙의 등장

디지털 시대에 개인정보 보호는 단순한 법적 요구사항을 넘어 개인정보의 권리를 존중하는 중요한 원칙으로 자리 잡고 있다. 다양한 데이터 처리 시스템과 빅데이터 분석의 확산에 따라 개인정보가 무분별하게 수집되고 사용될 위험이 커졌다. 이에 따라 개인정보 보호는 기업의 법적 책임이자 사회적 책무로 강조되고 있으며, 이를 효과적으로 실현하기 위한 방법론이 필요하다.

개인정보보호 중심 설계(Privacy by Design, PbD) 원칙은 개인의 프라이버시를 기술이나 서비스 설계의 초기 단계부터 내재화하려는 접근 방식이다.¹⁴⁾ 이는 기술적, 조직적 수단을 통해 개인정보 보호를 사전 예방적으로 적용하는 모델을 제시한다. 1990년대 초 앤 카부키안(Ann Cavoukian) 온타리오 개인정보 감독기관 위원장이 처음으로 제안한 이 원칙은 현재 전 세계적으로 개인정보 보호와 관련된 핵심 원칙 중 하나로 자리 잡았다.¹⁵⁾¹⁶⁾

이 글에서는 PbD 원칙의 국제 표준화 및 인증 제도 동향을 ISO 31700 시리즈¹⁷⁾, EU GDPR 제42조 인증 사례, 그리고 ePrivacy와 관련된 인증 프로그램을 중심으로 설명한다. 이를 통해 개인정보 보호의 글로벌 기준 및 기업이 이를 어떻게 실현할 수 있는지에 대해 논의한다.

2. PbD 원칙의 정의 및 이론적 배경

PbD는 개인정보 보호를 사전 설계로 통합하는 원칙으로, 기술적, 법적, 사회적 차원에서 개인정보 보호의 최적화를 목표로 한다. PbD의 핵심 아이디어는 개인정보 보호가 시스템 개발의 기본 설계 요소로 내재화되어야 한다는 것이다. 이는 법적 규제 준수를 넘어서, 기업의 조직적 가치로서 개인정보 보호의 구현을 목표로 한다. PbD는 다음과 같은 7원칙으로 정의된다.

14) 김나루, 'Privacy by design'의 도입과 그 적용에 관한 소고, 성균관법학, Vol.29(No.4), 2017.12.

15) 김남심·지성우, Privacy by design제도에 대한 규범적 고찰, 성균관법학, Vol.30(No.4), 2018.12.

16) Pardau, Stuart L. & Edwards, Blake, The FTC, the Unfairness Doctrine, and Privacy by Design: New Legal Frontiers in Cybersecurity, 2017.01.01.

17) ISO/IEC 31700:2023 Consumer protection — Privacy by design for consumer goods and services. 2023.01.

표1 PbD의 7원칙¹⁸⁾

원칙	주요 내용
1. 사후조치가 아닌 사전예방 (Proactive not Reactive; Preventative not Remedial)	프라이버시 침해 사고가 발생한 뒤 조치하는 것이 아닌 침해 사건을 예상하고 사전 예방
2. 초기설정부터 프라이버시 보호조치 (Privacy as the Default)	IT시스템 또는 사업 진행과정에서 개인정보가 보호될 수 있도록 자동 기본 설정하여 프라이버시 최대 보장
3. 프라이버시 보호를 내재한 설계 (Privacy Embedded into Design)	프라이버시 보호를 설계에 내재화함으로써 프라이버시를 IT 시스템 또는 개인정보 처리와 통합·적용
4. 제로섬이 아닌 포지티브섬 (Full Functionality – Positive-Sum, not Zero-Sum)	서비스 제공을 위한 기능성, 편리성 등과 프라이버시 보호 중 어느 하나도 포기하지 않고 프라이버시의 안전한 보호와 사업의 기능성 모두 확보하기 위해 노력
5. 개인정보 생애주기 전체에 대한 보호 (End-to-End Security – Lifecycle Protection)	개인정보의 수집·이용·저장·제공·파기 전 단계에 걸쳐 보호될 수 있도록 안전조치 적용
6. 개인정보 처리과정에 대한 가시성 및 투명성 유지 (Visibility and Transparency)	개인정보 처리과정에 대해 정보주체가 완전 하고 명확하게 이해하도록 하여 신뢰성 제고
7. 이용자 프라이버시 존중 (Respect for User Privacy)	프로그램, 프로세스 등에서 명시적인 보호 체계가 없더라도 사용자 프라이버시를 보장하기 위한 활동 수행

이 원칙들은 개인정보 보호를 설계의 핵심 요소로 삼아, 기업이 기술적, 조직적 요소를 통해 이를 실현할 수 있도록 하는 가이드라인을 제공한다.

3. ISO 31700 / 31700-2: 국제 표준의 발전과 사례

(1) 발전 방향

ISO 31700 시리즈는 Privacy by Design 원칙을 글로벌 표준으로 확립하려는 국제적 노력의 일환으로, 기업이 개인정보 보호를 제품 및 서비스 설계에 통합할 수 있도록 지원하는 도구이다. 이 시리즈는 ISO 31700-1과 ISO 31700-2로 구분되며, 각각 개인정보 보호 설계 지침과 실제 적용 방법을 제시한다.

먼저 ISO 31700-1 표준은 개인정보 보호를 설계의 초기 단계부터 반영하기 위한 전반적인 원칙과 절차를 제공한다. 이는 제품 개발 단계에서부터 개인정보 보호를 내재화하는 방법론을 제시한다.

이 ISO 31700-1 시리즈는 소비자 및 서비스 제품 전반의 생애주기(lifecycle) 동안 PbD 관점에서 지켜야 할 ‘상위 수준 요구사항(high-level requirements)’을 제시하는 데 구체적 기술 방법

18) Ann Cavoukian, Privacy by design- The 7 Foundational Principles: Implementation and Mapping of Fair Information Practices., 2011.01.

론이나 특정 기술을 지정하지 않고 있다.

또한 ISO 31700-2 표준은 제품 개발 및 서비스 설계 과정에서 개인정보 보호가 어떻게 실질적으로 적용될 수 있는지에 대해 구체적인 지침을 제공한다. 이 표준은 기업이 실제 설계 과정에서 개인정보 보호 기능을 어떻게 구현할 수 있는지에 대해 심도 있게 설명하고 있다

ISO 31700-2시리즈는 ISO 31700-1의 요구사항을 실제 사례(use case)를 통해 어떻게 적용 가능한지 보여주는 기술 보고서(Technical Report)이다. 이는 구체적인 예시를 통해 설계, 운영, 위험 관리, 소비자 커뮤니케이션 등 다양한 단계에서의 실무적 인사이트 제공한다.

(2) 사례

ISO 31700의 실제 적용 사례로는 스마트폰, IoT 기기, 클라우드 서비스 등이 있다. 예를 들어, 스마트폰 제조업체가 이 표준을 준수하는 경우, 사용자 데이터 암호화와 같은 기술적 보호를 설계에 반영하며, 동의 관리 시스템을 통해 사용자가 자신의 개인정보를 어떻게 통제할 수 있는지 보장한다. 이러한 접근은 개인정보 보호와 법적 요구사항을 동시에 충족시킬 수 있는 강력한 방법론을 제공한다. 구체적으로는 다음과 같은 분야에 주로 사용된다.

첫째, 온라인 리테일링 (On-line Retailing)분야이다. 이는 온라인 상점에서 소비자 개인정보 수집·처리·저장·폐기에 이르기까지의 흐름을 적시한다. 여기에는 제품 구매, 배송, 고객센터 등 여러 접점에서 소비자와의 커뮤니케이션, 데이터 수명 주기관리 등이 포함된다. 이 분야에는 소비자 통제 능력(design capabilities to enforce consumer privacy rights), 소비자 커뮤니케이션 (consumer communication), 위험 평가(risk assessment), 데이터 생애주기의 종료 처리(end of PII lifecycle) 등 다수 요구사항에서 적용된다.

둘째, 피트니스 분야에도 많이 적용된다. 여기에는 건강 앱 등 헬스케어 연관 서비스가 포함된다. 피트니스 분야는 건강 데이터/민감정보 취급, 제3자 협업, 사용자 커뮤니케이션, 위험 평가 등이 중요한 축이다. 이 분야에서는 민감 정보 취급 시 위험 관리, 제3자의 개인정보 처리능력 평가, 소비자 문의 및 불만 처리, 사용자 인터페이스/투명성 등이 강조된다.

셋째, 스마트 도어록(Smart Locks for Home Front Doors) 분야에도 적용된다. 이 기능을 위해서는 제품군, 다양한 구성(기본, 가족용, 공유 공간(co-location)용 등), 잠금장치의 설치/운영/소비자 커뮤니케이션, 보안 위험, 접근 제어, 제품 업데이트 및 운영 중 보안/프라이버시 유지 등이 검토된다. 이 분야에서는 제품 설계 및 배치(development, deployment, operation), 위험 평가, 소비자 정보 제공, 책임 배분, 생명주기 관리 등이 요구된다. 향후에는 스마트 헬스케어 기기

(Wearable Devices, Health Trackers), 가정용 IoT 기기 (예: 스마트 온도조절기, 스마트 조명, 스마트 스피커), 교육 서비스 앱/플랫폼, 금융 서비스/모바일 결제 앱, 소셜 미디어 또는 커뮤니티 플랫폼 등이 ISO 31700-1의 요구사항을 적용할 수 있는 분야로 자주 거론되고 있다.

4. GDPR 제42조: 인증 제도의 발전 및 사례

■ GDPR은 개인정보 보호의 세계적인 기준으로 자리 잡았다. 이 법률의 제42조는 개인정보 보호 인증에 관한 규정을 두어 기업이 개인정보 보호 법적 요구사항을 준수하는지 검증받을 수 있는 인증 시스템을 마련했다. 회원국의 개인정보 감독기관들, EU 개인정보보호이사회(European Data Protection Board, EDPB), 그리고 EU 집행위원회(European Commission, EC)는, 컨트롤러(controller) 및 프로세서(processor)가 본 규정을 준수함을 증명하기 위한 목적으로, 특히 EU 차원에서 개인정보 보호 인증 메커니즘(data protection certification mechanisms)과 개인정보 보호 씰(seals) 및 표시(marks)의 수립을 장려해야 한다. 또한 영세기업(micro), 소기업(small), 중기업(medium-sized enterprises)의 특정한 필요(specific needs)들도 고려해야 한다.

GDPR 제42조는 개인정보 보호 인증제도를 통해 기업이 GDPR 준수 여부를 외부 기관에 의해 독립적으로 평가받을 수 있게 한다. 기업은 자발적 인증(seals, marks, certificates)을 통해 개인정보 처리의 GDPR 준수 여부를 증빙할 수 있다. 이 규정은 인증 유효기간, 갱신 조건, 인증 기준(criteria)의 승인 절차, 인증기관의 독립성 및 전문성 등이 규정되어 있다. 이 규정들에 의해 EDPB가 ‘Guidelines 1/2018’을 제정했는데, 이를 통해 GDPR 제42조 및 제43조에 따른 인증 기준 및 인증기관의 승인에 대해 구체적인 지침을 마련했다.

최근에는 유럽데이터보호인증마크(European Data Protection Seal, Europrivacy)가 EDPB에 의해 공식적으로 승인된다. 이는 GDPR 제42조의 “common certification/seal” 중 하나인데, 인증을 받게 되면 EU-EEA 회원국 전체에서 통용된다. 먼저 Europrivacy(2022년 10월) 인증은 GDPR 준수 여부를 평가하는 독립적인 인증 프로그램이다. 이 인증은 특히 고위험 데이터 처리를 하는 기업에게 중요한 역할을 하며, 기업이 유럽 내에서 개인정보 보호 수준을 검증받을 수 있는 중요한 도구로 자리 잡고 있다. 둘째, European Privacy Seal(2024년 7월) 인증은 유럽에서 개인정보 보호를 준수하는 기업에게 수여되는 인증 프로그램이다. 이는 기업의 개인정보 보호 수준을 외부에 증명할 수 있는 중요한 지표로 기능한다. 셋째, BS 5701:2024(2024년 12월) 인증은 영국의 개인정보 보호법과 GDPR 준수 여부를 검토하는 시스템으로, 영국 시장에 중요한 의미를 가지며 영국의 개인정보 보호 및 보안 기준을 충족하는지를 판단한다.

5. ePrivacy 인증 및 PbD의 확장: 온라인 광고와 AdTech

■ ePrivacy 인증은 온라인 광고 및 AdTech(광고 기술) 분야에서도 PbD 원칙을 적용하고 있다. 지난 2023년 7월, ePrivacy Vendor Compliance Seal이 도입되었으며, 이는 온라인 광고 기술 업체들이 개인정보 보호를 적절히 처리하고 있는지 평가하는 새로운 인증 제도이다.¹⁹⁾ 이 인증은 GDPR과 ePrivacy 지침을 준수하는지를 검토하며, 특히 사용자의 개인정보 보호를 우선시하는 광고 시스템에 적용된다.

‘ePrivacy’에 대해선 두 가지 주요 개념이 있고, 인증은 이와 연관된다. 첫째, ePrivacy Directive/Regulation 분야에서는 EU에서 전자 통신(communications) 분야의 개인정보 보호 및 프라이버시를 다루는 법률 규제를 말한다. 여기에는 쿠키, 통신 비밀성, 스팸, 트래픽 데이터, 위치 데이터, 사용자 동의 등이 포함된다. 둘째, ePrivacy GmbH/ePrivacyseal 등 인증/인증기관(certification) 사업자 및 데이터 보호 인증 프로그램을 의미하기도 한다.

이는 법률 규제(ePrivacy Directive/Regulation/GDPR)와 디지털 제품/서비스의 프라이버시 준수를 평가해서 seal 또는 privacy 인증 마크를 부여하는 제도들을 총칭하는 개념이다. 여기에는 ePrivacyseal EU, ePrivacy Vendor Compliance Seal 등이 대표적이다.

이와 같은 인증 프로그램은 온라인 광고 산업에서의 개인정보 보호를 강화하고, PbD 원칙을 비즈니스 모델에 통합하는 중요한 역할을 한다.²⁰⁾ AdTech 기업은 이 인증을 통해 개인정보 보호와 법적 요구사항을 준수하고 있다는 것을 외부에 입증할 수 있으며, 이는 소비자 신뢰와 브랜드 평판을 강화하는데 기여한다.

6. 결론: PbD 원칙의 글로벌 확산과 향후 전망

■ PbD 원칙은 기업이 개인정보 보호를 설계의 핵심으로 삼게 하는 중요한 기준이 되고 있으며, 이를 위한 국제 표준과 인증 제도는 점차 확산되고 있다.²¹⁾ ISO 31700 시리즈와 GDPR 제42조의 인증 제도는 기업이 개인정보 보호 법적 요구사항을 준수하고 있다는 것을 입증하는 중요한 수단으로 자리 잡고 있다.

19) ePrivacy, ePrivacy Vendor Compliance Seal, 2022.07.

20) Virtual Minds, Certificate for privacy-compliant programmatic advertising: Virtual Minds is the first adtech provider to receive the “ePrivacy Vendor Compliance Seal”, 2023.06.07.

21) 한국인터넷진흥원, 개인정보보호 중심 설계(Privacy by Design) 인증제도 동향 및 국내 도입방안 검토, 2022.08.17.

향후 PbD 원칙은 온라인 광고를 포함한 다양한 산업 분야로 확장될 것이며, 기업은 기술적, 조직적 방안을 통해 개인정보 보호를 내재화해야 할 필요성이 커질 것이다. 이러한 인증 제도들은 기업의 법적 책임을 다하는 동시에, 소비자 신뢰와 사회적 책임을 증진하는 중요한 역할을 하게 될 것이다.

하지만 인증을 실제 받은 기업이 많지 않고, 인증 제도의 활용도 및 보급률이 아직 초기 단계이다. 인증 기준 승인, 인증기관의 인증 능력(accreditation), 인증 비용 및 절차의 복잡성이 이 제도가 확산되는 데 장애가 되고 있다.

ePrivacy Regulation도 통신 프라이버시, 메시지 암호화, 쿠키/추적기(tracker) 관리 등의 영역에서는 불확실성이 존재한다. 또한 국가별 구현 및 집행(enforcement)에도 차이가 있다.

GDPR은 Regulation이므로 회원국 법률에 직접 적용되지만, ePrivacy나 인증제도는 실제 실행 세부 사항에서 차이가 있는 상황이다. 이는 기술 변화 속도를 법이 따라가야 하는 과제이다. 향후 AI, IoT, 빅데이터, 사물인터넷 등의 발전이 개인정보 보호의 새로운 문제가 제기되고 있는바, 인증 기준, 법적 틀, 감독 당국의 역량 강화 필요하다. 결론적으로 개인정보 보호의 중요성이 지속적으로 증가하는 가운데, PbD 원칙을 준수하는 기업은 글로벌 디지털 시장에서의 경쟁력을 확보할 수 있을 것이다.

참고 문헌 |

1. 김나루, 'Privacy by design'의 도입과 그 적용에 관한 소고, 성균관법학, Vol.29(No.4), 2017.12.
2. 김남심·지성우, Privacy by design제도에 대한 규범적 고찰, 성균관법학, Vol.30(No.4), 2018.12.
3. Pardau, Stuart L. & Edwards, Blake, The FTC, the Unfairness Doctrine, and Privacy by Design: New Legal Frontiers in Cybersecurity, 2017.01.01.
4. ISO/IEC 31700:2023 Consumer protection — Privacy by design for consumer goods and services. 2023.01.
5. Ann Cavoukian, Privacy by design- The 7 Foundational Principles: Implementation and Mapping of Fair Information Practices., 2011.01.
6. ePrivacy, ePrivacy Vendor Compliance Seal, 2022.07.
7. Virtual Minds, Certificate for privacy-compliant programmatic advertising: Virtual Minds is the first adtech provider to receive the "ePrivacy Vendor Compliance Seal", 2023.06.07.
8. 한국인터넷진흥원, 개인정보보호 중심 설계(Privacy by Design) 인증제도 동향 및 국내 도입방안 검토, 2022.08.17.

AI 환경에서의 PbD 적용방안

조수영

숙명여자대학교 법학과 | 교수

1. 연구배경

■ 생성형 AI 기술의 개발로 AI는 자료 검색, 상담, 소프트웨어 개발, 작곡, 영상제작, 문서 작성 및 번역·요약 등의 업무를 신속하게 처리하며 다양한 분야의 생산성 향상에 기여하고 있기에, 우리는 AI 기술이 우리들의 삶에 직·간접적으로 영향을 주는, 이른바 ‘AI시대’에 살고 있다. 우리는 AI 기술을 직접 눈으로 확인할 수 있는 경우뿐 아니라 이를 직접 목도할 수 없는 경우에도 4차 산업혁명시대의 흐름 속에서 데이터 기반의 사회로 나아감에 따라 점점 더 고도화되고 있는 초연결·초융합·초지능 환경의 구축으로 인해 AI기술이 추천, 보안 강화, 사기 탐지, 질병 예측, 교통 안내, 자율주행차 운행 등 다양한 기능을 수행하고 있다는 사실을 인지하고 있으며, 이처럼 AI기술은 우리에게 다양한 순기능을 제공하고 있다. 그러나 양질의 데이터를 지속적으로 학습해야만 보다 실효성 있는 AI 기술로 발전할 수 있지만, 양질의 데이터 확보와 개인정보 침해 가능성은 표리 관계에 있어 이러한 기술의 이점과 함께 개인정보 보호에 대한 우려도 커지고 있다.

무엇보다 AI 서비스 단계에서도 암기된 개인정보가 원본 그대로 출력되거나 개인 식별 또는 민감정보 추론 목적으로 운용될 수 있어 정보주체 권익침해 측면에서 리스크를 가지고 있는 것도 사실이기에²²⁾ 기획(설계)단계에서부터 개인정보 보호를 위한 사전 조치를 취할 필요성이 대두되고 있으며, 정보주체의 신뢰를 기반으로 한 데이터 활용 환경 모색을 위한 효과적 방법론 도출은 ‘AI시대’의 풀어야할 과제라 할 수 있다. 그리고 이 과제 해결을 위해 어떤 철학과 방법 또는 프레임워크를 채택할 것인가와 관련해서는 ‘개인정보보호 중심 설계(Privacy by Design, PbD)’가 필수적 요소로 작용할 만큼 중요하다. 이에 PbD를 기반으로 AI(신기술 포함)의 기획·설계 단계에서 개인정보 침해 위험을 줄이기 위한 우리나라 개인정보 보호법의 적용 가능성 및 해외 법정책 등의 분석을 통해 AI환경에서 개인정보 침해 위험이 발생하기 전에 예방하기 위한 방법론은 무엇이 있는지 등을 살펴보고, 이를 통해 AI환경에서의 PbD 적용방안을 모색해 보고자 한다.

22) 개인정보보호위원회, 개인정보보호 연차보고서, 2020.08.24., p.29

2. 설명가능성과 투명성의 원칙 준수를 위한 PbD 적용 필요성

주지하는 바와 같이 캐나다의 앤 카부키안(Ann Cavoukian) 박사가 개발한 PbD는 개인정보 보호가 선택 사항이 아닌 당연히 내재되어야 할 기본 원칙이어야 한다는 개념을 기반으로 하는 철학이자 방법론으로 AI의 기획(설계)단계부터 개인정보 생애주기 모든 단계에서 윤리적인 데이터 처리를 위해 준수해야 할 모범 기준이라 할 수 있다.

표1 PbD의 7대 주요 원칙

원칙	주요 내용
제1원칙: 사후 대응이 아닌 사전 예방 (시정 조치가 아닌 예방)	위험이 발생하기 전에 예측하고, 침해가 발생할 때까지 기다리는 것이 아님
제2원칙: 개인정보 보호를 기본 설정	개인이 개인정보 보호를 요청할 필요가 없어야 하며, 자동으로 설정되어야 함
제3원칙: 개인정보 보호 기능 사전 설계	개인정보 보호 기능이 나중에 추가되는 것이 아니라 기본적으로 내장되어 있으므로 개인정보 보호 중심의 시스템 구축 필요
제4원칙: 제로섬이 아닌 포지티브섬을 통해 완전한 기능성 구현	개인정보 보호와 혁신을 모두 달성해야 하며, 어느 한쪽을 희생해서 다른 쪽을 이룰 수는 없음
제5원칙: 중단 간 보안 및 생명 주기 보호	데이터가 수집되는 순간부터 삭제될 때까지 데이터를 보호해야 함
제6원칙: 가시성과 투명성	시스템은 검사, 검토, 설명에 개방적이어야 함
제7원칙: 이용자 개인정보 존중	간단한 통제와 명확하고 솔직한 의사소통을 통해 이용자 중심의 환경 마련

AI는 데이터를 기반으로 학습하고 활용한다는 점에서, 표면적으로는 개인정보와 무관할 것 같은 데이터도 학습을 통해 특정인의 민감한 정보를 추론할 수도 있어(예: 음성, 텍스트, 이미지 또는 행동 훈련된 모델은 이용자 성향뿐만 아니라 기분, 정치적 성향, 건강 상태까지 파악 가능) 기존의 일반 소프트웨어와는 상당히 다른 특징을 가지고 있다.

그 때문에 AI 환경에서 데이터를 과도하게 수집하거나 적법한 근거 없이 추론된 데이터를 활용하거나 환각 또는 블랙박스 현상 등에 대한 공정성 및 편향성 검증 절차 없이 정보주체의 자유와 권리에 직·간접적 영향을 줄 수 있는 프로세스를 기획(설계)한다면, 결과적으로 개인정보 보호법 등의 위반에 따른 과징금 등의 법적 제재 외에 각종 소송에 휘말릴 수 있으며, 법에 따른 제재까지 받지 않는다고 하더라도 윤리적 면에서도 문제가 되어, 고객과 시민사회의 신뢰 상실, 기업(기관) 이미지 추락의 원인이 될 수 있다. 케임브리지 애널리티카(Cambridge Analytica) 및 클리어뷰 AI(Clearview AI)²³⁾ 사례가 대표적인 예라 할 수 있다.

23) 미국의 안면 인식 기술 업체 Clearview AI는 100억 건의 얼굴 사진을 불법 수집한 혐의로 영국 개인정보 감독기관(ICO)은 950만 달러의 과징금을 부과했으며, 2024년 9월 네덜란드 개인정보 감독기관 (DDPA)으로부터 불법 데이터베이스 구축 혐의로 3,050만 유로(약 450억원)의 과징금을 부과한 바 있음.

EU의 AI Act를 포함한 세계 각국의 AI 법정책은 이러한 문제점 해결을 위해, AI에 대한 설명 가능성을 포함한 투명성의 원칙(GDPR의 투명성 의무 포함)을 준수토록 요구하고 있는바²⁴⁾, 이는 법적 요구사항 준수를 통한 책임 추적성 확보 및 개인의 자유와 권리 보호에 관한 효과적 대응을 위해 필수적으로 요구되는 방법이기 때문이다. 특히 AI의 설명가능성과 관련해 다양한 방법과 유형이 존재하지만, 영국의 개인정보 감독기관(Information Commissioner's Office, ICO)은 다음과 같은 유형을 구분하고 있다.

표2 AI의 설명가능성에 대한 유형²⁵⁾

유형	주요 내용
근거 설명	AI가 어떤 결정을 내리게 된 이유를 일반인이 접근하기 쉽고 기술적이지 않은 방식으로 설명
책임 설명	AI 시스템의 개발, 관리 및 구현에 누가 관여하는지, 그리고 결정에 대한 인간 검토를 위해 누구에게 연락해야 하는지를 설명
데이터 설명	AI가 내린 특정 결정에 어떤 데이터가 어떻게 사용되었는지 설명
공정성 설명	AI 시스템의 설계 및 구현 전반에 걸쳐 해당 시스템이 지원하는 결정이 일반적으로 편견 없고 공정하며, 개인이 공평하게 대우받도록 하고 있는지 등 설명
안전성 및 성능에 대한 설명	AI 시스템의 설계 및 구현 전반에 걸쳐 의사 결정과 행동의 정확성, 신뢰성, 보안성 및 견고성을 극대화하기 위한 조치 사항 설명
영향에 대한 설명	AI 시스템의 설계 및 구현 전반에 걸쳐 AI 시스템 사용 및 결정이 개인과 사회 전체에 끼칠(또는 끼칠 가능성) 영향을 고려하고 모니터링하는 단계 등에 대한 설명

즉, AI의 설명가능성과 투명성의 원칙 준수를 위해 PbD관점에서의 개인정보보호법 준수가 필요하며, PbD 구현을 위한 가장 효과적 도구라 할 수 있는 데이터 보호 영향평가의 수행이 필요하다.²⁶⁾

3. 해외 법정책

■ 2018년도부터 시행되고 있는 GDPR은 ‘개인정보 보호 설계(Protection by Design)’ 원칙의 적용의 일환으로 제35조를 통해 ‘데이터 보호 영향평가(Data Protection Impact Assessment, DPIA)’를 규정하고 있으며, 특히 “신기술을 사용하는 데이터의 처리 유형과 처리의 특성, 범위, 맥락 및 목적을 고려할 때 자연인의 권리와 자유에 높은 위험을 초래할 가능성이 있는 경우”, 컨트롤러는 처리를 실시하기 전에 예상되는 처리 작업이 프라이버시(개인정보 보호)에 미치는 영향을 평가토록 하고 있다.

24) AI 시스템에 인적 개입이 있는 경우에도 투명성 요건을 준수해야 함

25) ICO, Explaining decisions made with AI, 2022.10.17.

26) 미국, 영국, 캐나다 등을 중심으로 PbD의 구현을 위한 지침이나 평가도구를 개발해 배포하고 있음.

2025년 2월부터 시행 중에 있는(일부 조문 제외) EU의 인공지능법(Artificial Intelligence Act, AI Act)²⁷⁾ 제27조제4항은 조직이 GDPR 제35조에 따라 수행되는 DPIA를 통해 [중략...] 본 조에 명시된 의무를 충족하는 경우, 본 조 제1항에 언급된 기본권 영향평가(Human Rights Impact Assessment, HRIA)는 해당 DPIA를 보완해야 함을 명시하고 있다.

EU의 DPIA와 HRIA를 비교하면 아래의 표와 같다.

표3 GDPR의 DPIA와 AI Act의 HRIA 비교

구분	DPIA	HRIA	비고
처리 목적	○	X	· DPIA: 기획(설계)단계에서 처리의 목적을 요구함 · HRIA: 기획(설계)단계에서 개인정보 처리의 목적과 비례성을 명시적으로 요구하지 않음
처리 설명	○	○	· DPIA: 컨트롤러의 개인정보 처리 작업에 대한 설명 필요 · HRIA: 배포자의 데이터 처리에 대한 설명 필요
처리의 적법 근거 (처리의 목적과의 비례성)	○	X	· HRIA가 개인정보 처리의 목적과 비례성을 명시적으로 요구하지 않지만, 컨트롤러가 AI 시스템의 투명성 원칙 준수를 위해 처리의 적법성이 요구됨
개인의 자유와 권리에 대한 침해 위험	○	○	· DPIA: 처리 작업의 특성, 범위, 내용 및 목적을 고려하여 개인에 대한 침해 위험을 포함해야 함 · HRIA: 평가 시 AI 시스템 제공자가 제공한 정보를 고려하여 개인에 대한 특정 침해 위험을 포함해야 함
위험 분석 및 관리에 관한 사항	○	○	· DPIA: 개인정보 보호를 보장하고 GDPR 준수를 입증하기 위한 보호 장치 및 보안 조치를 요구함 · HRIA: 위험이 발생할 경우 대응조치, 내부 AI 거버넌스 및 불만 처리 메커니즘을 요구함
영향을 받을 가능성이 있는 자연인의 범주	X	○	· GDPR 제35조는 DPIA에 정보 주체 범주를 포함할 것을 의무화하지 않지만, 조직은 논리적으로 개인의 권리와 자유에 대한 위험을 파악하기 위해 이러한 세부 정보를 포함해야 함
인적 감독 조치의 구현	X	○	· GDPR 제22조는 프로파일링 등 자동화된 개별 의사결정에 관한 정보주체의 권리보장을 위해 필요한 경우 인적 개입 조치를 취하도록 규정하고 있으나, DPIA 과정에서 요구하는 조치는 아님

DPIA와 HRIA가 개인의 자유와 권리에 끼치는 영향을 분석해 침해 위험을 줄인다는 점에서 공통점이 있으나, HRIA가 고위험 AI 시스템이 개인의 자유와 권리에 미치는 영향 분석 및 위험 완

27) 2025년 2월부터 시행 중에 있는(일부 조문 제외) EU의 인공지능법(Artificial Intelligence Act)은 EU 내에서 AI 시스템을 제작, 사용, 수입 또는 배포하는 모든 사람에게 적용하며, EU 밖에서 제작되었다고 EU 내에서 사용되는 AI 시스템에도 적용되는 바(제2조), AI 시스템을 '다양한 수준의 자율성으로 작동하도록 설계되고 배포 후 적응성을 보일 수 있으며 명시적 또는 암묵적 목적에 대해 수신한 입력에서 예측, 콘텐츠, 권장 사항 또는 물리적 또는 가상 환경에 영향을 줄 수 있는 결정과 같은 출력을 생성하는 방법을 추론하는 기계 기반 시스템'으로 정의하며(제3조), 공급자(제공자; provider), 배포자(deployer), 수입자(importer), 유통업자(distributor), 운영자(operator), 다운스트림 공급자(downstream provider), 권한을 위임받은 대리인(authorised representative) 등으로 행위주체를 구분해 각각의 행위주체별 의무사항을 규정하고 있으며, AI 시스템 개발 단계에서 AI 시스템을 운영하고 사용하는 직원 및 그 밖의 관련된 자들의 AI 리터러시(활용 능력)를 최대한 보장하기 위한 절차와 방법(입증 가능토록 문서화 포함)을 마련토록 하고 있다(제4조).

화에 중점을 두고 있다면, DPIA는 개인의 자유와 권리에 영향을 끼치는 개인정보 처리 작업에 중점을 두고 처리 작업의 목적, 범위, 맥락 등과 관련된 정보를 고려해 개인정보가 보호되도록 위험을 완화하는 데 중점을 두고 있다. 따라서 DPIA와 HRIA가 서로 유사한 제도가 아니라 개인의 자유와 권리 보호를 위해 서로 보완관계에 있는 제도라 할 수 있으며, EU의 AI Act 제27조제4항에서 DPIA의 수행 시 HRIA가 DPIA를 보완토록 규정하고 있는 이유는 이 때문이라 할 수 있다.

AI 및 개인정보 보호에 대한 지침(Guidance on AI and Data Protection)의 경우 규정준수 의무자(개인정보보호책임자(Data Protection Officer, DPO), 법률 고문, 위험 관리자, 고위경영진, ICO 자체 감사관 등과 기술·서비스의 개발에 참여하는 연구기관·제조사·개발자 등에게 AI 기술 개발 시 영향평가를 수행하도록 권고하고 있으며²⁸⁾, ‘AI가 내린 결정에 대한 설명가능성’의 충족을 위해 표4에서 확인할 수 있는 바와 같이 AI의 생애주기를 설계(기획)단계, 데이터 수집 단계, 훈련 및 테스트, 배포/모니터링 단계로 구분해 요구사항을 구체적으로 안내하고 있는 것이 특징이며, 이중 AI의 책임성과 관리체계 구축을 위해 DPIA를 수행할 것을 요구하고 있다.

표4 영국 ICO의 AI 및 데이터 보호 위험 툴킷 중 설계(기획)단계

유형	주요 내용
근거 법령	UK GDPR 전문 제74항-제77항, 제5조제2항, 제35조, 제36조, 제84조, 제89조-제92조, 94조, 제95조
데이터 침해 위험	위험 평가를 수행하지 않을 경우, 개인의 권리와 자유에 대한 위험을 잘못 식별할 가능성 있음 → 결과적으로 조직은 개인에게 발생하는 피해를 예방하기 위한 적절한 관리적/기술적 조치를 마련할 수 없음
통제 방법	데이터 보호 영향평가(DPIA) 수행
통제 목표	위험을 사전에 파악하고 줄이기 위한 적절한 관리적/기술적 조치 수행
대응 방법	1. DPIA 수행: 개인에게 높은 위험을 초래할 가능성이 있는 처리에 대해서는 DPIA를 수행해야 함 2. 이해당사자와 협의: AI 사용으로 인해 영향을 받을 가능성이 있는 개인과 협의해야 함 3. 위험도를 줄일 수 없는 고위험이 발견된 경우 처리를 시작하기 전에 ICO와 협의해야 함 4. 부서 협의: DPIA의 일환으로, 프로젝트에 참여할 조직 내 팀과 협의하여 AI 프로젝트의 데이터 보호 위험을 파악해야 함 (협의대상: 엔지니어링 팀, 법무 및 규정 준수 팀, 의사 결정 과정에 참여하는 관계직원 등) 5. 전문가 상담: 필요한 경우 위험도를 낮추기 위한 관계 전문가와 상담

미국의 경우 미국 안전, 보안과 신뢰 가능한 인공지능의 개발과 사용에 관한 행정명령(Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence Executive Order 14110)²⁹⁾에서 이 행정명령의 8대 원칙 중 하나인 개인정보 보호 원칙을 통해 AI가 사람들

28) 2025년 6월 19일부터 시행된 데이터(이용 및 접근)법(Data Use and Access Act 2025)에 따라 본 지침은 현재 검토 중이며 향후 일부 내용이 변경될 수 있음.

29) 이 행정명령이 트럼프 정권 후 개정명령을 받았기에, 추후 개정사항을 지켜볼 필요가 있음.

의 신원, 위치, 습관, 그리고 욕구에 대한 민감한 정보를 추출, 재식별, 연결, 추론하고 이를 바탕으로 행동하는 것을 더욱 용이하게 만들고 있으며, 이와 관련해 AI의 역량은 개인정보가 악용되고 노출될 위험을 증가시킬 수 있기에 미국인의 개인정보보호 및 시민의 자유 보호를 위해 '개인정보 보호 강화기술(Privacy-Enhancing Technologies, PETs) 활용, 개인정보보호 및 기밀유지 위험 완화를 위한 표준 및 절차를 마련할 것을 규정한 바 있으며(제2조f호), 영향평가를 수행토록 안내하고, 'AI 레드팀 편성(AI red-teaming)³⁰⁾'을 규정해 위험 완화를 위한 절차를 안내하고 있으며, NIST의 'AI 위험 관리 프레임워크'는 다음과 같은 체크리스트를 통해 점검토록 하고 레드팀 편성을 통해 테스트 절차를 정책화하고 있다.

표5 NIST 'AI 위험 관리 프레임워크' 중 조직의 위험관리정책 (체크리스트)

NIST 'AI 위험 관리 프레임워크' 중 조직의 위험관리정책 (체크리스트)	
① AI 시스템과 관련된 주요 용어와 개념, 그 목적과 의도된 사용 범위를 정의하였는가?	
② AI 관리체계(거버넌스)를 기존 조직 관리체계(거버넌스) 및 위험 관리와 연결되도록 하였는가?	
③ 특히 민감하거나 위험한 데이터의 사용에 있어 보다 광범위한 데이터 거버넌스 정책과 관행을 준수토록 하였는가?	
④ 실험 설계, 데이터 품질, 모델 학습에 대한 세부적인 표준을 준수하고 있는가? (또는 표준을 마련하였는가?)	
⑤ 위험 매핑, 측정 프로세스 및 표준을 개략적으로 설명하고 문서화하였는가?	
⑥ 세부적인 모델 테스트 및 검증 프로세스가 존재하는가?	
⑦ 법률 및 위험 관리 기능에 대한 세부 검토 프로세스가 존재하는가?	
⑧ 모니터링, 감사 및 검토 프로세스의 빈도와 세부 사항을 설정하였는가?	
⑨ 변경 관리 요구 사항을 간략하게 설명할 수 있는가? (또는 이러한 절차를 마련하고 있는가?)	
⑩ 내부 및 외부 이해 관계자 참여를 위한 프로세스를 개략적으로 설명할 수 있는가? (또는 이러한 절차를 마련하고 있는가?)	
⑪ 심각한 AI 시스템 문제를 보고하기 위한 고발자 보호 정책을 수립하였는가?	
⑫ 사고 대응 계획을 세부적으로 작성하고 테스트하는 절차를 마련하였는가?	
⑬ 공식적인 AI 위험 관리 정책이 기존 법적 기준, 업계 모범 사례 및 규범에 부합하는지 확인하였는가?	
⑭ 신뢰할 수 있는 AI 시스템 특성에 광범위하게 부합하는 AI 위험 관리 정책을 수립하였는가?	
⑮ 공식적인 AI 위험 관리 정책에 현재 배포된 AI 시스템과 타사 AI 시스템이 포함되어 있는지 확인하였는가?	

4. 국내 현황 및 발전 방향

■ 우리나라의 경우 오는 2026년 1월 22일부터 시행되는 인공지능 발전과 신뢰 기반 조성 등에 관한 기본법(이하 인공지능기본법)은 인공지능을 “학습, 추론, 지각, 판단, 언어의 이해 등 인간이 가진 지적 능력을 전자적 방법으로 구현한 것”으로 정의하며(제2조제1호), 이 법 제35조에 따르면, 인공지능사업자는 고영향 인공지능³¹⁾을 이용한 제품 또는 서비스를 제공하는 경우 사전에 사람

30) AI 시스템의 결함과 취약점을 찾기 위한 체계적인 테스트 활동을 말하며, 일반적으로 통제된 환경에서 AI 개발자와 협업하여 수행된다. AI 레드팀은 일반적으로 전담 '레드팀'이 수행하는 경우가 흔하며, AI 시스템의 유해하거나 차별적인 출력, 예상하지 못하거나 바람직하지 아니한 시스템 작동, 한계 또는 시스템의 오용과 관련된 잠재적 위험 등과 같이 AI 시스템의 결함과 취약점을 적대적으로 식별토록 함

31) 사람의 생명, 신체의 안전 및 기본권에 중대한 영향을 미치거나 위험을 초래할 우려가 있는 인공지능시스템으로 인공지능기본법

의 기본권에 미치는 영향을 평가(이하 고영향 인공지능 영향평가)토록 권고하고 있다. ‘고영향 인공지능 영향평가’는 주무부처인 과학기술정보통신부가 관계기관과의 협의를 통해 구체적인 절차와 방법을 마련 중에 있다. 한편, 이와 관련해 국민인권위원회에서는 법 제정 과정에서 “고영향 인공지능 영향평가” 가이드라인을 제시한 바 있는데 다음과 같은 방법과 절차를 안내하고 있으며, 모든 단계에서 이해관계자의 의견수렴을 권장하고 있고, 개인정보와 관련해서는 개인정보보호위원회 <인공지능(AI) 개인정보보호 자율점검표>³²⁾를 준수토록 하고 있으며, 인공지능 시스템의 개인정보 처리에 대해 데이터 보호 영향평가를 수행했는지 개발자에게 질의해 평가팀이 자체적으로 평가한 내용과 비교, 분석함으로써 객관적인 평가를 수행토록 안내하고 있다. 다만, 우리나라의 경우 신뢰할 수 있는 AI환경 구축을 위해 인공지능기본법과 개인정보 보호법과의 모호한 관계를 보다 명확히 규정하고, 개인정보 보호법에 PbD에 관한 사항을 법제화해 개인정보처리자가 아닌 시스템 개발자 등도 개인정보 보호법을 준수해 시스템을 설계할 수 있도록 의무화할 필요가 있다.

제2조제4호 각목의 어느 하나의 영역에서 활용되는 것을 말함 (인공지능기본법 제2조제4호)

32) 이 자율점검표(2021.05.31)는 AI 프라이버시 리스크 관리 모델(25.2)로 개정됨. (개인정보위, AI 프라이버시 리스크 관리 모델, 2024.12.19.)

참고 문헌 |

1. 개인정보보호위원회, 개인정보보호 연차보고서, 2020.08.24.
2. ICO, Explaining decisions made with AI, 2022.10.17.
3. ArtificialIntelligenceAct.eu, Artificial Intelligence Act, 2024.07.12.
4. EUR-Lex, General Data Protection Regulation (GDPR), 2016.05.04.
5. Federal Register, Executive Order 14110: Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence, 2023.10.30.
6. CISA, Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Secure by Design Software, 2023.06.
7. ENISA, A multilayer framework for good cybersecurity practices for AI, 2023.06.
8. ICO, AI and data protection risk toolkit, 2022.05.05
9. 개인정보보위, AI 프라이버시 리스크 관리 모델, 2024.12.19.

PRIVACY REPORT

개인정보 이슈 심층분석

「2025 개인정보 이슈 심층분석 보고서」는
개인정보보호위원회의 출연금으로 수행한 사업의 결과물입니다.

한국인터넷진흥원의 승인 없이 본 보고서의 무단전재나 복제를 금하며,
인용 출처 「2025 개인정보 이슈 심층분석 보고서」를 밝혀주시기 바랍니다.

본 보고서의 내용은
한국인터넷진흥원의 공식 견해가 아님을 알려드립니다.